

Marco Integrativo GQM + PRAGMATIC

Aplicado a indicadores TIBER-EU / TIBER-ES

1. Objetivo del marco

Articular una cadena de trazabilidad completa:

Objetivos nacionales de ciberresiliencia

- Metas GQM sectoriales
- Preguntas GQM por dimensión TIBER
- Métricas técnicas concretas
- Evaluación PRAGMATIC de cada métrica

Con ello se busca:

- Evitar indicadores “decorativos” separados de los objetivos de TIBER-EU/TIBER-ES y DORA.
- Priorizar métricas con alto valor operativo y regulatorio.
- Disponer de un lenguaje común entre regulador, entidad y comunidad técnica.

2. Recordatorio de los componentes

2.1. GQM

- Goal (Meta): declaración de alto nivel, orientada a negocio/regulador.
- Question (Pregunta): formulación operativa que permite evaluar el grado de consecución de la meta.
- Metric (Métrica): dato cuantitativo o cualitativo estructurado que responde a la pregunta.

2.2. PRAGMATIC

Cada métrica se evalúa según nueve criterios (0–5, de peor a mejor):

1. Predictivo – ¿Ayuda a anticipar problemas futuros?
2. Relevante – ¿Está directamente ligada a objetivos TIBER/DORA?
3. Accionable – ¿Sugiere acciones concretas cuando empeora?
4. Genuino – ¿Mide lo que dice medir (sin proxies engañosos)?
5. Significativo – ¿Su variación es significativa, no ruido?
6. Preciso – ¿Es medible con baja ambigüedad?
7. Oportuno – ¿Está disponible con la frecuencia necesaria?
8. Independiente – ¿No es fácilmente manipulable?
9. Rentable – ¿Su coste de obtención es proporcionado?

3. Dimensiones TIBER y metas GQM

Trabajaremos con cinco dimensiones principales, alineadas con el informe de indicadores:

10. Gobernanza y CIFs (GOV).
11. Inteligencia de amenazas (TI).
12. Red Team y escenarios (RT).
13. Detección y respuesta (BLUE).
14. Purple teaming, remediación y aprendizaje (PRP).

Para cada una se define al menos una meta GQM, un conjunto de preguntas y un subconjunto de métricas.

4. Ejemplo de desarrollo GQM por dimensión

4.1. Dimensión GOV – Gobernanza y CIFs

Goal GOV-1

Asegurar que las funciones críticas o importantes (CIFs) están correctamente identificadas, priorizadas y cubiertas por pruebas TIBER, de forma coherente con el apetito de riesgo nacional y con DORA.

Questions principales

- Q-GOV-1: ¿La entidad dispone de un inventario formal y actualizado de CIFs aprobado por su órgano de administración?
- Q-GOV-2: ¿En qué medida las CIFs se basan en análisis de impacto de negocio (BIA)?
- Q-GOV-3: ¿Qué porcentaje de CIFs ha sido cubierto por pruebas TIBER en los últimos tres años?
- Q-GOV-4: ¿Cuál es el grado de implicación del Consejo en la aprobación del alcance TIBER?

Metrics asociadas (ejemplos)

- M-GOV-1: Existencia y frecuencia de revisión del inventario de CIFs (0–5).
- M-GOV-2: Porcentaje de CIFs sustentadas en BIA documentado.
- M-GOV-3: Porcentaje de CIFs cubiertas por al menos una prueba TIBER en 3 años.
- M-GOV-4: Puntuación de implicación del Consejo (0–5).

4.2. Dimensión TI – Inteligencia de amenazas

Goal TI-1

Garantizar que los escenarios TIBER se basan en inteligencia de amenazas actual, específica y alineada con el perfil de riesgo nacional y sectorial.

Questions

- Q-TI-1: ¿Utiliza la entidad un GTL sectorial como entrada al TTIR?
- Q-TI-2: ¿Cuál es la calidad y relevancia del TTIR respecto de amenazas recientes?
- Q-TI-3: ¿Se actualiza el TTIR durante el test para incorporar nueva información?
- Q-TI-4: ¿Se integra la inteligencia del TTIR en los procesos del SOC y de gestión de riesgos?

Metrics

- M-TI-1: Uso de GTL sectorial (sí/no/mixto).
- M-TI-2: Puntuación de alineamiento TTIR-amenazas reales (0–5).
- M-TI-3: N° de actualizaciones del TTIR durante el test.
- M-TI-4: Grado de integración del TTIR en procesos internos (0–5).

4.3. Dimensión RT – Red Team y escenarios

Goal RT-1

Asegurar que las pruebas TIBER-EU/TIBER-ES exploran adecuadamente las superficies de ataque críticas con un nivel de agresividad y realismo suficiente.

Questions

- Q-RT-1: ¿Cuántos escenarios se diseñan y ejecutan por prueba?
- Q-RT-2: ¿Cuál es la diversidad de TTPs utilizadas?
- Q-RT-3: ¿Qué porcentaje de banderas se alcanza sin leg-ups?
- Q-RT-4: ¿Cuál es la frecuencia y justificación de los leg-ups?

Metrics

- M-RT-1: N° de escenarios ejecutados en la prueba.
- M-RT-2: N° de familias de TTPs empleadas.
- M-RT-3: % banderas logradas sin leg-ups.
- M-RT-4: N° de leg-ups por escenario (media).

4.4. Dimensión BLUE – Detección y respuesta

Goal BLUE-1

Medir y mejorar la capacidad de detección y respuesta de la entidad frente a ataques avanzados en CIFs.

Questions

- Q-BLUE-1: ¿Cuál es el MTDD de las actividades del RTT en escenarios críticos?
- Q-BLUE-2: ¿Cuál es el MTTR desde detección hasta contención?
- Q-BLUE-3: ¿Qué porcentaje de actividades del RTT es detectado en tiempo real?
- Q-BLUE-4: ¿Qué proporción de detecciones relevantes proviene de usuarios de negocio?

Metrics

- M-BLUE-1: MTDD (categorías convertibles a valores).
- M-BLUE-2: MTTR (categorías).
- M-BLUE-3: % actividades detectadas en tiempo real.
- M-BLUE-4: N°/porcentaje de detecciones originadas por negocio.

4.5. Dimensión PRP – Purple teaming y remediación

Goal PRP-1

Cerrar el ciclo de aprendizaje asegurando que los hallazgos TIBER se traducen en mejoras medibles en controles, procesos y cultura.

Questions

- Q-PRP-1: ¿Se realizan ejercicios formales de purple teaming tras las pruebas?
- Q-PRP-2: ¿Se observa mejora en MTTD/MTTR tras los ejercicios de purple?
- Q-PRP-3: ¿Qué porcentaje de recomendaciones críticas y altas se implementa en plazos predefinidos?
- Q-PRP-4: ¿Existe un proceso formal de lecciones aprendidas con el Consejo?

Metrics

- M-PRP-1: Indicador de existencia/intensidad de purple teaming (0–5).
- M-PRP-2: % de mejora observada en MTTD en escenarios repetidos.
- M-PRP-3a: % recomendaciones críticas implementadas en 12 meses.
- M-PRP-3b: % recomendaciones altas implementadas en 24 meses.
- M-PRP-4: Puntuación de formalidad del proceso de lecciones aprendidas (0–5).

5. Integración con PRAGMATIC

Cada métrica M-X-Y será puntuada en la Matriz PRAGMATIC según nueve columnas:

- PRED, REL, ACC, GEN, SIG, PREC, OPOR, IND, RENT.

Estas puntuaciones permitirán:

- Filtrar métricas poco útiles (por ejemplo, alta precisión pero baja relevancia y accionabilidad).
- Priorizar las que tienen mejor combinación de relevancia, predicción y coste razonable.
- Ajustar el diseño de la encuesta y del cuadro de mando nacional.

6. Salida: selección de métricas “estrella”

Una vez aplicado PRAGMATIC, se propondrá:

- Un conjunto de indicadores núcleo (core) de alto valor.
- Un conjunto de indicadores complementarios para entidades con más madurez.

Esta selección alimentará:

- La plantilla Excel de IGM y ROI.
- El cuadro de mando nacional.
- Los resúmenes ejecutivos para reguladores y entidades.

Fin del Marco Integrativo GQM + PRAGMATIC.